

## HTB ACADEMY

# Incident Handling Process

HTB Academy · Module · SOC / Incident Response Track · Walkthrough

A complete illustrated walkthrough of the NIST incident-handling lifecycle, capped by a full breach case study ("Insight Nexus") and a TheHive-based skills assessment. Lab-specific answers are partially masked as a hint, matching HTB's sharing guidance.

|                    |                                                                          |
|--------------------|--------------------------------------------------------------------------|
| <b>Platform</b>    | HackTheBox Academy                                                       |
| <b>Module</b>      | Incident Handling Process                                                |
| <b>Completion</b>  | 100% — all 11 sections                                                   |
| <b>Analyst</b>     | Chayan Panchal · @tron874                                                |
| <b>Core Skills</b> | NIST IH lifecycle, Cyber Kill Chain, MITRE ATT&CK, TheHive, IOC analysis |

## 1 Definitions & Scope

| Term                 | Definition                                                                           |
|----------------------|--------------------------------------------------------------------------------------|
| Event                | Any action in a system/network — a mouse click, a firewall rule match, an email sent |
| Incident             | An event with a negative consequence — a crash, a breach, a power failure            |
| IT Security Incident | An event with clear intent to cause harm to a computer system                        |
| Incident Handling    | A formally defined set of procedures for managing and responding to incidents        |

### The NIST incident-handling lifecycle



NIST IH Lifecycle — 4 Cyclic Phases

#### 1. PREPARATION

Build IH capability; write policies/docs/tool kits; train the workforce

#### 2. DETECTION & ANALYSIS

Monitor via sensors/logs/SIEM; triage alerts; build a timeline

#### 3. CONTAINMENT, ERADICATION & RECOVERY

Contain spread; remove root cause; restore normal ops

#### 4. POST-INCIDENT ACTIVITY

Final report; lessons learned; update playbooks and readiness

**NOTE** IH scope is broader than intrusions — it covers insider threats, availability issues, data loss, and physical disasters too.

### Real-world incidents referenced in the module

| Category            | Incident                     | Root cause                                         |
|---------------------|------------------------------|----------------------------------------------------|
| Leaked credentials  | Colonial Pipeline ransomware | Inactive VPN account, no MFA                       |
| Default credentials | Mirai Botnet (2016)          | IoT devices shipped with admin/admin               |
| Unpatched systems   | Equifax breach (2017)        | Unpatched Apache Struts CVE; 147M exposed          |
| Unpatched systems   | WannaCry (2017)              | EternalBlue SMB exploit; 200K+ systems             |
| Insider threat      | Cash App / Block (2022)      | Ex-employee abused legitimate access; 8.2M records |
| Supply chain        | SolarWinds Orion (2020)      | Backdoor injected into the Orion update pipeline   |

## 2 Cyber Kill Chain & MITRE ATT&CK



### Cyber Kill Chain — 7 Stages

#### 1. RECONNAISSANCE

Target selection — passive (LinkedIn, job ads) or active (scans)

#### 2. WEAPONIZE

Craft AV-evasive malware/exploit; goal is access + persistence

#### 3. DELIVER

Phishing email, malicious link, vishing call, or a USB drop

#### 4. EXPLOIT

Payload triggers; attacker executes code on the target

#### 5. INSTALL

Dropper, backdoor, or rootkit installed for persistence

#### 6. C2

Remote access established; modular tools loaded for resilience

#### 7. ACTION / OBJECTIVE

Final goal: exfiltration, ransomware, sabotage, lateral spread

**NOTE** Attackers loop back — after Install they re-run Recon to find new targets. The goal is to stop them as early in the chain as possible.

### The Pyramid of Pain — what actually hurts an attacker

| Level       | Indicator type         | Attacker cost to change                              |
|-------------|------------------------|------------------------------------------------------|
| Trivial     | Hash values            | Trivial — recompile or byte-pad the binary           |
| Easy        | IP addresses           | Easy — spin up a new server in minutes               |
| Simple      | Domain names           | Cheap — register a new domain                        |
| Annoying    | Network/host artifacts | Moderate — must change tooling configs               |
| Challenging | Tools                  | Significant effort to rebuild tooling                |
| Tough       | TTPs (MITRE-based)     | Forces fundamental behavioural change — maximum pain |

**WHY IT MATTERS** This is why MITRE ATT&CK-based detection (behavioural, TTP-level) is worth so much more than a blocklist of IPs or hashes — it's the hardest thing for an attacker to change.

### 3 Preparation — Documentation, Tools & Protective Measures

#### The jump bag — tools that are always ready to grab and go

| Category      | Items                                                                    |
|---------------|--------------------------------------------------------------------------|
| Workstations  | Forensic workstation per handler; AV disabled; no org network connection |
| Acquisition   | Disk imaging tools, memory capture tools, write blockers, spare drives   |
| Analysis      | Live response tools, log analysis tools, network capture tools           |
| Documentation | Chain-of-custody forms, IOC creator, encryption software, ticket system  |

**NOTE** Documentation infrastructure must be fully independent of the org's own network. Assume the entire domain is compromised — use out-of-band communications only.

#### Protective measures covered in the module

| Measure                | Key points                                                                                                                         |
|------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| DMARC                  | Rejects spoofed email claiming to be from your domain; built on SPF + DKIM                                                         |
| Endpoint hardening     | CIS/Microsoft baselines, LAPS, ConstrainedLanguage PowerShell, ASR rules, block .hta/.vbs/.cmd/.bat/.js from user-writable folders |
| MFA & passwords        | MFA on all admin access; passphrases over complex-but-weak passwords                                                               |
| Vulnerability scanning | Continuous scanning; remediate High/Critical; segment if unpatchable                                                               |
| Purple team exercises  | Red team attacks while informing blue team — tests detection + IR playbooks in the real environment                                |

## 4 Detection, Analysis & IOCs

Detection sources covered: employee reports, security tooling (EDR/IDS/Firewall/SIEM alerts), proactive threat hunting, and third-party notification. Defence-in-depth means detection happens at the network perimeter, the internal network, the endpoint, and the application layer simultaneously.

### The 3-step cyclic investigation process



#### IOC-Driven Investigation Loop

##### 1. CREATE & USE IOCS

Document indicators (OpenIOC, YARA, STIX/JSON); search org-wide

##### 2. IDENTIFY NEW LEADS

Triage IOC hits; eliminate false positives; prioritise leads

##### 3. COLLECT & ANALYSE DATA

Forensic collection; live response preferred; chain of custody



#### Example STIX IOC (JSON)

```
"type": "file"
"MD5": "40e609840ef3f7fea94d53998ec9f97f"
"SHA-256": "3461da3a2ddcccd4a00f87dcd7650af48f97998a3ac9ca649d7ef3b7332bd997"
"name": "osvmhdf1.dll"
```

**CAUTION** Never cache privileged credentials on a potentially compromised system. WinRM (Logon Type 3, Network Logon) does not cache credentials remotely — PsExec with explicit credentials does.

## 5 Containment, Eradication & Recovery

| Sub-stage              | Actions                                                                                             |
|------------------------|-----------------------------------------------------------------------------------------------------|
| Short-term containment | Isolate to a VLAN, pull the cable, sinkhole C2 DNS — minimal footprint, preserve for forensics      |
| Long-term containment  | Change passwords, apply firewall rules, install HIDS, patch — notify stakeholders                   |
| Eradication            | Remove all malware and footholds; rebuild or restore from clean backup; root cause fully eliminated |
| Recovery               | Restore to production after verification; heavy logging on all restored systems                     |

**NOTE** All containment actions must be coordinated and executed simultaneously across every affected system. Piecemeal containment tips off the attacker and produces unpredictable consequences.

## 6 Post-Incident Activity

The final report has to answer six questions: what happened and when; how the team performed against existing plans/playbooks; whether the business responded promptly; what containment/eradication actions were taken; what preventive measures should follow; and what tools or resources are needed for next time. Incident reports are admissible in court, drive budget decisions, and double as training material for new team members — they're worth writing properly even under time pressure.

## 7 Case Study — the Insight Nexus Breach

The module's capstone case study: Insight Nexus, a mid-sized market research firm running an internet-facing ManageEngine ADManager Plus instance and a PHP upload portal — both became entry points for two unrelated threat actors operating at the same time.

| Actor         | Type                     | Motivation                                                 |
|---------------|--------------------------|------------------------------------------------------------|
| Crimson Fox   | State-backed APT         | Credential theft, long-term persistence, data exfiltration |
| Silent Jackal | Low-skill criminal group | Opportunistic web defacement, proof-of-concept intrusion   |

### Attack chain, in order



#### Crimson Fox — Full Kill Chain on Insight Nexus

##### 1. INITIAL ACCESS

ManageEngine console — default credentials admin/admin worked

##### 2. EXECUTION

Java RCE exploit; outbound C2 established over HTTPS

##### 3. DISCOVERY

AD enumeration; new Domain Admin account created; found an exposed RDP host

##### 4. LATERAL MOVEMENT

RDP logon (LogonType 10) to the exposed host, using a service account

##### 5. COLLECTION

Accessed the file share; located client project data

##### 6. PERSISTENCE

GPO-deployed disguised MSI installer pushed to every domain machine

##### 7. EXFILTRATION

Data archived to a zip and exfiltrated over HTTPS

### Key event log evidence used to build the timeline



#### Correlated evidence across the environment

Sysmon Event ID 3 (Network Connection)

Image: C:\ManageEngine\jre\bin\java.exe DestinationPort: 443

Windows Event ID 4624 (Successful Logon)

LogonType: 10 (RDP) SubjectUserName: i.....c.....r

Sysmon Event ID 11 (File Create)

TargetFilename: C:\Windows\Temp\java-update.msi

Sysmon Event ID 1 (Process Create)

CommandLine: msixexec /i C:\Windows\Temp\java-update.msi /quiet

### MITRE ATT&CK mapping for the full incident

| Phase          | Technique                               | ID            |
|----------------|-----------------------------------------|---------------|
| Reconnaissance | Active scanning of public assets        | T1595         |
| Initial Access | Valid accounts (default credentials)    | T1078.004     |
| Initial Access | Exploit public-facing application (PHP) | T1190         |
| Persistence    | Scheduled tasks / services / GPO MSI    | T1547 / T1543 |
| C2             | HTTPS web protocols                     | T1071.001     |
| Exfiltration   | Archive and upload project data         | T1560 / T1041 |

**LESSON** Deleting Silent Jackal's marker file did not neutralise Crimson Fox's root cause — two unrelated actors were active at once, and treating the obvious one as "the incident" would have missed the real breach. Always investigate fully, even after finding an easy answer.

## 8 Skills Assessment — TheHive & MITRE Quick Reference

The assessment simulates working the case inside TheHive: creating a case, linking tagged alerts, assigning roles (Triage Analyst, Forensics Lead, Containment Lead, Comms Lead), enriching indicators via VirusTotal, and setting case priority to Critical once exfiltration is confirmed.

| Activity                       | MITRE ID  | Name                                    |
|--------------------------------|-----------|-----------------------------------------|
| C2 tool download via wget/curl | T1105     | Ingress Tool Transfer                   |
| Credential-store access        | T1555     | Credentials from Password Stores        |
| LSASS memory dump (Mimikatz)   | T1003.001 | OS Credential Dumping: LSASS Memory     |
| Encoded PowerShell execution   | T1059.001 | Command & Scripting: PowerShell         |
| Registry run-key persistence   | T1547.001 | Boot/Logon Autostart: Registry Run Keys |
| External RDP access            | T1021.001 | Remote Services: RDP                    |

**MASKING NOTE** Every specific answer value below (usernames, hashes, IPs, file paths) is partially masked, in line with HTB's guidance on not publishing exact graded answers.



### Skills assessment answers (masked)

```
Parent process of the credential-dumping tool -> C.....l.....e
imagePath for the DB01 persistence mechanism -> C.....P.....e
External IP for the zip exfiltration           -> 9.....4
User who accessed the file share               -> s...a...n
VirusTotal file referring to the C2 IP        -> M.....a.....e
Whois city for the second suspicious IP       -> L....n....s
IP decoded from the encoded PowerShell command -> 1.....4
User who ran the suspicious PowerShell        -> C.....c.....e
Hash for the VaultCli.dll alert               -> F.....B.....5
```

## 9 Quick Reference — Frameworks & Process

### Frameworks & process quick reference

|                             |                                                                                             |
|-----------------------------|---------------------------------------------------------------------------------------------|
| NIST IH LIFECYCLE           | Preparation -> Detection & Analysis -><br>Containment/Eradication/Recovery -> Post-Incident |
| CYBER KILL CHAIN            | Recon -> Weaponize -> Deliver -> Exploit -><br>Install -> C2 -> Actions on Objectives       |
| PYRAMID OF PAIN (low->high) | Hashes -> IPs -> Domains -> Host artifacts -><br>Tools -> TTPs                              |
| IOC FORMATS                 | OpenIOC, YARA, STIX/JSON                                                                    |
| SIGMA RULE FIELDS           | title / logsource / detection / condition / level                                           |